

FICHA DE LECTURA Y DEFENSA DE UN CONTRATO

6 PÁGINAS
UNA COPIA POR CONTRATO

EQUIPO	CONTRATO QUE SE LEE (ARCHIVO .SOL)	FECHA
QUIÉNES LO LEEN (NOMBRES)	¿DE QUIÉN ES EL CONTRATO?	N.º DE LÍNEAS

PARA QUÉ SE ESTÁ LLENANDO ESTA COPIA · MARCAR UNA

- ☐ S7 · laboratorio, contrato del docente
 ☐ S7 · bloque C, nuestro propio contrato
 ☐ S8 · preparar la defensa
 ☐ S9 · auditoría cruzada (contrato ajeno)
 ☐ Otro

LA REGLA DE ORO

Si no pueden responder las cuatro pasadas sobre su propio contrato, ese contrato todavía no es suyo. Da igual quién escribió las líneas: si nadie del equipo sabe por qué una línea está ahí, el equipo no controla el sistema que está construyendo.

Un contrato no se lee de arriba abajo como una novela: se lee cuatro veces, buscando una cosa distinta cada vez, **una página de esta ficha por pasada**. **1 · ¿Qué promete?** solo nombres, sin abrir ningún cuerpo. **2 · ¿Quién manda?** direcciones privilegiadas y qué puede cada una. **3 · ¿Por dónde entra y sale el dinero?** `payable`, `msg.value`, saldos y envíos. **4 · ¿Qué pasa si...?** la pasada del adversario, que es la que encuentra los fallos. Las tres primeras son inventario y se hacen con lápiz, sin correr nada.

01 ¿Qué promete?

SOLO NOMBRES · NO SE LEEN LOS CUERPOS

FUNCIONES PÚBLICAS Y EXTERNAS · incluyan también las HEREDADAS (ERC-20, ERC-721, Ownable, AccessControl...): un contrato responde por lo que hereda

FUNCIÓN (FIRMA)	¿GASTA GAS?	¿PAY-ABLE?	¿HERE-DADA?	SOLO POR EL NOMBRE, ¿QUÉ PROMETE QUE HACE?
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	
	☐ S ☐ N	☐ S ☐ N	☐ S ☐ N	

EVENTOS Y ERRORES DECLARADOS

EVENTOS (QUÉ DEJA POR ESCRITO)	ERRORES (QUÉ PROMETE RECHAZAR)

LAS TRES PREGUNTAS QUE CIERRAN LA PASADA 1 · una línea cada una

- ☐ **a** · ¿Alguna función cambia el estado y NO emite ningún evento? ¿Cuál?
- ☐ **b** · ¿Hay algún error declarado que NINGUNA función pública parezca poder lanzar? Ese es el cabo suelto: alguien lo lanza desde adentro.
- ☐ **c** · ¿Qué promete el contrato que NO aparece en ninguna firma? La regla principal suele vivir en un `modifier` o en un `override`.

PASADA 2 · ¿QUIÉN MANDA?

CONTRATO: _____
EQUIPO: _____

Recorran el estado buscando **todas** las direcciones guardadas y **todos** los controles de acceso (`onlyOwner` , roles, comparaciones con `msg.sender`). Una fila por cada poder. La última columna es la que casi nadie llena y la que más pesa en la defensa.

QUIÉN (ROL O DIRECCIÓN)	DÓNDE SE GUARDA / CÓMO SE comprueba	QUÉ PUEDE HACER (FUNCIONES EXACTAS)	QUÉ NO PUEDE HACER	SI ESA LLAVE SE PIERDE O SE FILTRA, ¿QUÉ PASA?
-------------------------	-------------------------------------	-------------------------------------	--------------------	--

QUIÉN PUEDE CAMBIAR QUIÉN MANDA

PREGUNTA	SÍ / NO	FUNCIÓN Y LÍNEA · QUÉ IMPLICA
¿Se puede traspasar el mando? (<code>transferOwnership</code> , cambio de rol)	☐ S ☐ N	
¿Se puede renunciar al mando? (<code>renounceOwnership</code>) ¿Qué queda sin dueño si se llama?	☐ S ☐ N	
¿El traspaso es en dos pasos (el nuevo acepta) o en uno solo?	☐ S ☐ N	
¿Hay pausa, rescate de fondos, lista negra o actualización del código?	☐ S ☐ N	
¿Algún privilegiado puede tocar bienes o dinero de otros?	☐ S ☐ N	

LA PREGUNTA QUE CASI NADIE SE HACE · ¿QUÉ COSAS NO PUEDE HACER NADIE, NUNCA, NI SIQUIERA EL DUEÑO?

Parámetros `immutable` , reglas sin función de cambio, registros que no se pueden corregir. La inmutabilidad corta para los dos lados y hay que poder decirlo en voz alta.

EL DÍA MALO · ESCRIBAN EL ESCENARIO COMPLETO DE LA LLAVE PERDIDA

Elijan la llave más poderosa de la tabla de arriba y cuenten qué pasa exactamente ese día: qué deja de funcionar, qué dinero queda inmovilizado, a quién hay que avisar, y si existe alguna salida. Si la respuesta es «se acabó», escríbanlo tal cual: es una respuesta válida y es lo que el docente pregunta en la defensa.

PASADA 3 · ¿POR DÓNDE ENTRA Y SALE EL DINERO?

CONTRATO: _____

EQUIPO: _____

Busquen `payable`, `msg.value`, los mapas de saldos y todos los envíos (`transfer`, `send`, `call{value:}`), transferencias de tokens). Si el contrato no mueve valor, escriban «no mueve valor» y expliquen en una línea qué **otro** bien custodia: un registro, una identidad, un permiso. Esa cosa tiene las mismas preguntas.

PUERTA (FUNCIÓN)	ENTRA / SALE	¿CUÁNTO, Y QUÉ LO VALIDA?	¿DÓNDE QUEDA ANOTADO?	¿QUIÉN LO PUEDE SACAR, Y CÓMO?

EL BALANCE · TODO LO QUE ENTRA TIENE QUE TENER UNA SALIDA CON NOMBRE Y DUEÑO

PREGUNTA	SÍ / NO	DÓNDE SE VE · QUÉ IMPLICA
¿Cada wei que entra queda anotado a nombre de alguien?	☐ S ☐ N	
¿Hay dinero que puede entrar y no salir nunca? ¿Cuánto, y en qué caso?	☐ S ☐ N	
¿Hay <code>receive</code> o <code>fallback</code> ? ¿Qué pasa si llega ether a secas?	☐ S ☐ N	
¿Se usa el patrón de retiro (acreditar y que el titular reclame) o se envía dentro de la operación?	☐ S ☐ N	
¿Se comprueba el valor que devuelve cada envío?	☐ S ☐ N	
¿El pago exigido es exacto, mínimo o libre? ¿Qué pasa si pagan de más?	☐ S ☐ N	

EL ORDEN DE LAS LÍNEAS, QUE AQUÍ ES TODO

Por cada función que envíe valor o llame a código ajeno, comprueben el orden: **primero las comprobaciones, después los cambios de estado, y de últimas la llamada hacia afuera** (*checks-effects-interactions*). Escriban abajo, para la función que más valor mueve, las líneas en el orden en que aparecen, y señalen cuál es la llamada hacia afuera.

SI EL CONTRATO NO MUEVE DINERO · ¿QUÉ BIEN CUSTODIA, Y QUIÉN SE PERJUDICA SI SE PIERDE O SE FALSIFICA?

PASADA 4 · ¿QUÉ PASA SI...?

CONTRATO: _____
EQUIPO: _____

Esta lista sirve para **cualquier** contrato. Recórranla entera, una pregunta por fila. «No aplica» es una respuesta válida **si se justifica**; «no se me ocurrió» no lo es. Lo que encuentren se pasa a la página 5 con el formato de hallazgo.

#	LA PREGUNTA	¿APLI- CA?	¿EN QUÉ FUNCIÓN?	QUÉ PASA · Y CÓMO LO COMPROBÉ
1	¿Y si el receptor revierte ? ¿Queda bloqueado el atacante o una víctima?	☐ S ☐ N		
2	¿Y si lo llamo dos veces ? ¿Qué impide la segunda: la regla, o algo accidental?	☐ S ☐ N		
3	¿Y si lo llamo desde otro contrato , sin usar la interfaz oficial?	☐ S ☐ N		
4	¿Y si el plazo ya pasó ? ¿Y un segundo antes? ¿Y en el segundo exacto?	☐ S ☐ N		
5	¿Y si quien llama no es quien creo ? (permiso delegado, operador, tx.origin)	☐ S ☐ N		
6	¿Y si el monto es cero ? ¿Y el límite exacto? ¿Y uno más que el límite?	☐ S ☐ N		
7	¿Y si la llave del dueño se pierde o se filtra? (viene de la pasada 2)	☐ S ☐ N		
8	¿Esta función llama a código que no escribí yo ? (envío de ether, aviso a un receptor, token ajeno, oráculo)	☐ S ☐ N		
9	Si lo hace: ¿ qué queda a medio camino en ese instante ? ¿Qué variable abierta, qué saldo sin descontar, qué bandera encendida?	☐ S ☐ N		
10	¿Y si alguien se adelanta a mi transacción viéndola pendiente?	☐ S ☐ N		
11	¿Y si no existe o está vacío ? (un id que nadie creó, la dirección cero)	☐ S ☐ N		
12	¿Y si crece sin límite ? (un bucle sobre una lista que cualquiera alarga)	☐ S ☐ N		

LAS PREGUNTAS 8 Y 9 SON LAS QUE MÁS FALLOS ENCUENTRAN

Salieron del laboratorio de la Sesión 7, donde un contrato con pruebas verdes y especificación escrita se rompió exactamente ahí. La regla que dejó: **el control se pone en el punto por donde pasa el estado, no en cada puerta; y todo lo que entregue el control a código ajeno debe dejar el estado ya cerrado antes de hacerlo.**

LA REGLA PRINCIPAL · ¿DÓNDE ESTÁ LA LÍNEA QUE LA HACE CUMPLIR (ARCHIVO, FUNCIÓN, LÍNEA), Y QUÉ PASA SI LA BORRO?

HALLAZGOS DE LA PASADA 4

Un hallazgo sin **ubicación** y sin **recomendación** está incompleto. Las severidades y los seis campos son los mismos de `auditoria-cruzada.pdf` : **Crítica** (pérdida directa de fondos o control, fácil de explotar) · **Alta** (pérdida con alguna condición) · **Media** (impacto acotado) · **Baja** (riesgo menor) · **Informativa** (calidad o gas, no explotable). Clasificar bien una cosa que *no* es vulnerable vale tanto como encontrar un fallo; inflar severidades resta credibilidad. **Si encuentran más de dos, impriman otra copia de esta página.**

HALLAZGO 1 · TÍTULO	SEVERIDAD: CRÍTICA · ALTA · MEDIA · BAJA · INFORMATIVA
UBICACIÓN · ARCHIVO, FUNCIÓN Y LÍNEA EXACTA	
DESCRIPCIÓN · QUÉ ESTÁ MAL Y POR QUÉ, EN DOS O TRES FRASES	
ESCENARIO DE EXPLOTACIÓN · LOS PASOS CONCRETOS (O, SI ES INFORMATIVO, POR QUÉ NO ES EXPLOTABLE)	
RECOMENDACIÓN · LA CORRECCIÓN MÍNIMA, NO UNA REESCRITURA	

HALLAZGO 2 · TÍTULO	SEVERIDAD: CRÍTICA · ALTA · MEDIA · BAJA · INFORMATIVA
UBICACIÓN · ARCHIVO, FUNCIÓN Y LÍNEA EXACTA	
DESCRIPCIÓN	
ESCENARIO DE EXPLOTACIÓN	
RECOMENDACIÓN	

LÍMITES, QUE NO SON HALLAZGOS · cosas que el contrato NO puede impedir por su naturaleza, no por un error: pagos por fuera de la cadena, acuerdos entre personas, lo que pase con el dispositivo del usuario. No se corrigen con código; se enuncian.

CONCLUSIÓN DE LA LECTURA, EN UNA LÍNEA · «no hallamos vulnerabilidades explotables; revisamos esto y esto» es una conclusión válida y vale

LA PREGUNTA QUE CIERRA TODO

Con lo que sabemos hoy, ¿pondríamos dinero propio en este contrato? ☐ Sí ☐ Sí, con las correcciones de arriba ☐ No

☐ No sabemos todavía

Por qué:

LA DEFENSA

TRES PREGUNTAS FIJAS
NO CAMBIAN NUNCA

Estas tres preguntas se hacen **siempre**, a todos los equipos, sobre cualquier contrato. Están impresas aquí porque no son una sorpresa: la única forma de fallarlas es no haber leído el contrato propio. Preparen la respuesta por escrito y después díganla sin leer.

PREGUNTA 1 · SEÑALEN LA LÍNEA QUE HACE CUMPLIR SU REGLA PRINCIPAL, Y DIGAN QUÉ PASA SI LA BORRO

Buena: archivo, función y línea; qué comprueba; qué deja de ser cierto sin ella; la prueba que lo demuestra. · **Mala:** «está protegido con OpenZeppelin».

PREGUNTA 2 · ¿QUIÉN PUEDE QUEDARSE CON EL DINERO O CON EL CONTROL SI PIERDE O FILTRA SU LLAVE, Y QUÉ PASA CON EL SISTEMA ESE DÍA?

Buena: nombra el rol, el monto o el poder en juego, y cuenta el día malo completo, incluida la salida si la hay. · **Mala:** «guardamos bien las claves».

PREGUNTA 3 · DIGAN UNA COSA QUE SU CONTRATO NO PUEDE IMPEDIR, Y POR QUÉ SIGUEN PENSANDO QUE VALE LA PENA

Buena: enuncia el límite sin exagerarlo ni minimizarlo, y argumenta qué se gana igual. · **Mala:** «no se nos ocurre ninguna», o «entonces no sirve para nada». Las dos dicen que no se pensó.

CONTRATOS ESCRITOS CON AYUDA DE IA

Usar una IA para escribir el contrato está bien y no hay que esconderlo. El problema no es usarla: el problema es **no poder defender lo que produjo**. En la sustentación nadie va a preguntar quién tecleó; van a preguntar por qué esa línea está ahí, y la respuesta «la puso la IA» es la misma respuesta que «no sé».

La regla práctica, y es solo una: si nadie del equipo sabe por qué una línea está ahí, **esa línea se borra o se entiende**. No hay tercera opción. Un contrato con diez líneas menos que el equipo domina es mejor que uno con cien que nadie puede explicar, porque lo que no se entiende no se puede probar, y lo que no se prueba falla donde nadie mira.

Y una advertencia de oficio: una IA escribe código que compila, que suena razonable y que viene con una explicación convincente. Eso no es lo mismo que código que hace lo que ustedes creen. El contrato del laboratorio de la Sesión 7 estaba escrito a mano, revisado, documentado y con todas sus pruebas en verde, y aun así tenía un fallo que dejaba salir una entrada por fuera del tope. **Lo que protege no es quién escribió: es haber leído en cuatro pasadas y haber probado.**

ANTES DE SUSTENTAR · MARCAR LO QUE SEA CIERTO

- ☐ Recorrimos el contrato línea por línea y no quedó ninguna que no sepamos explicar. ☐ Sabemos qué trae cada `import` y por qué está.
- ☐ Cada función tiene al menos una prueba escrita por nosotros. ☐ Comprobamos lo que la herramienta afirmó, en vez de creerle.
- ☐ Las cuatro pasadas de esta ficha están llenas.

QUIÉN RESPONDE CADA PREGUNTA (1 · 2 · 3)

FIRMA DEL EQUIPO

FECHA